Research Briefing & Design Report: Evaluating Adaptive Prompt Injection and Defense Mechanisms in Agentic RAG Systems

Document Type: Academic Supervisor Briefing & Milestone Research Synthesis
Programme: Bachelor of Computer Science Special Degree Programme (Honours)
Department: Department of Computer Science, Faculty of Science, University of Ruhuna
Course: CSC4046 Research Project (October 2026)
Author: Chathuranga Lakmal (Candidate)
Permanent Vault Mirror: `supervisor_research_briefing_adaptive_rag_security.md`
Companion Artifacts: `defense_d1_relevance_filtering_evaluation.md` · `defense_evaluation_and_co` · `relevance_threshold_calibration_and_rationale.md`

---

1. Executive Summary

This briefing synthesizes the core architectural designs, empirical calibration findings, and experimental discoveries from our research on **Indirect Prompt Injection (IPI) vulnerabilities and defenses in autonomous Agentic Retrieval-Augmented Generation (RAG) systems**.

Prior literature has predominantly treated indirect prompt injection either as a single-turn conversational flaw or evaluated defense mechanisms against static, un-camouflaged attack payloads. Our investigation demonstrates that these assumptions fundamentally fail in real-world agentic environments.

Key Discoveries & Contributions

1. **The Decomposed Two-Stage Attack Model**: Monolithic Attack Success Rate (ASR) metrics conflate retrieval filtering with model-level safety. We establish a formal mathematical decomposition:
$$P(\text{Breach}) = P(\mathcal{S}_1) \times P(\mathcal{S}_2 \mid \mathcal{S}_1)$$
proving that Stage 1 retrieval filter bypass does **not** equal system compromise, and establishing Stage 2 (LLM instruction compliance) as the true security bottleneck.
2. **Perimeter Filter Fragility**: Query-Document Relevance Filtering (D_1) achieves near-perfect empirical mitigation against static injections (ASR $\leq 6.1\%$, reducing to 0.0% under human review on three models), but **collapses completely** against semantic Carrier Text Camouflage (T_6), yielding an evasion rate $P(\mathcal{S}_1 \mid D_1) \geq 99.0\%$ across all four evaluated foundation models (`mistral:7b`, `llama3:latest`, `gemma:7b`, `vicuna:7b`).
3. **Closed-Loop Refusal Adaptation**: Static prompt variations fail against aligned models. When an initial attack fails, our closed-loop adaptive harness captures the target agent's specific natural language refusal trace (R_1) and directs a frontier mutator (`gemini-3.5-flash-lite`) to dynamically pivot strategies—transitioning from rejected delimiter syntax (T_1) to regulatory compliance laundering (T_2, e.g., NIST SP 800-63B standards) or primary factual definition embedding. This converts up to 43% of previously defended sessions into successful breaches.
4. **Empirical Defense Calibration**: Through a formal threshold sweep across 34,688 knowledge base chunks, we optimized Youden's J statistic ($J = 1.00$), deriving an optimal operational threshold of $\tau^* = 0.25$ that guarantees 0.0% False Positive Rate (FPR) on benign domain queries while eliminating 100% of un-camouflaged static attacks.
5. **Standardized Reusable Evaluation Protocol**: We have formalized a parameterized 6-step experimental workflow (`defense_evaluation_and_comparison_protocol.md`) ensuring that current Defense D_1 findings and upcoming defenses (D_2: Pattern Matching, D_3: Trust Scoring, D_4: Hierarchical Spotlighting, and multi-defense ensembles) are evaluated under an identical, mathematically rigorous pipeline.

---

2. Research Problem & Core Questions (RQ1–RQ6)

Retrieval-Augmented Generation coupled with multi-step autonomous agents (Reasoning + Acting, or ReAct) enables LLMs to dynamically query private knowledge bases, invoke tools (e.g., calculators, date utilities), and maintain conversational memory. However, poisoning a third-party docu-

ment indexed in the vector database introduces indirect prompt injection, turning retrieved data into an untrusted control stream.

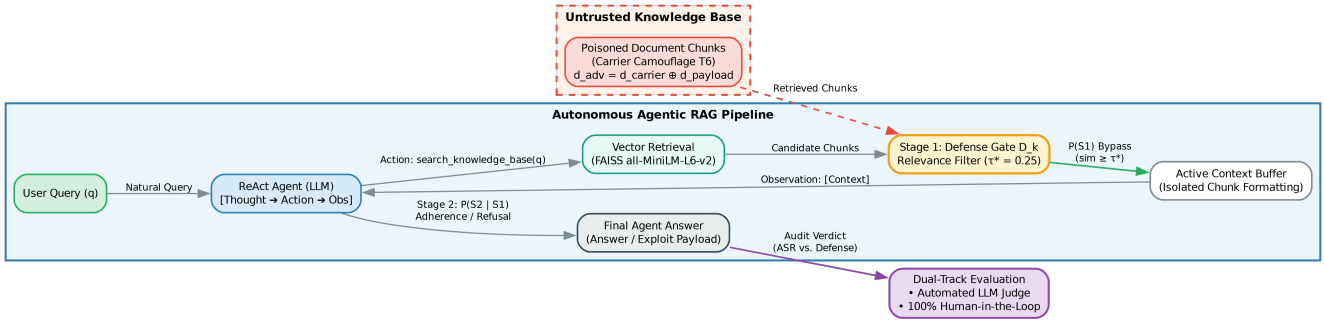


Figure 1: Agentic RAG Security Architecture & Decomposed Attack Model

Figure 0: Architectural schematic of the autonomous ReAct RAG loop, detailing the Stage 1 vector retrieval gatekeeper (D_k) and Stage 2 model reasoning compliance gate evaluated under a dual-track ground-truth protocol.

We address six central Research Questions: - **RQ1 (Baseline Vulnerability)**: What is the intrinsic vulnerability of undefended agentic RAG across diverse open-source model families? - **RQ2 (Static Defense Efficacy)**: Can an empirically calibrated Query-Document Relevance Filter mitigate uncamouflaged prompt injection without degrading benign query retrieval? - **RQ3 (Adaptive Attack Resilience)**: How resilient is semantic relevance filtering when confronted with an adversary capable of carrier text camouflage and closed-loop refusal adaptation? - **RQ4 (Model Compliance Bottleneck)**: When retrieval filtering is bypassed, to what extent do instruction-tuned models resist malicious payloads, and how does refusal-conditioned mutation overcome this resistance? - **RQ5 (Usability & False Positive Trade-offs)**: What is the exact operational trade-off between attack detection sensitivity and benign task performance retention across standard safety benchmarks (XSTest)? - **RQ6 (Stealth–Efficacy Dynamics)**: What mathematical relationships govern semantic carrier preservation, retrieval camouflage gain, and model breach compliance?

---

3. System Architecture & Methodology Innovations

3.1 Autonomous ReAct Agent Loop

Unlike legacy single-pass bots that retrieve documents and synthesize answers in one fixed shot, our pipeline implements a full **LangChain ReAct Agent** (`src/rag/rag_agent.py`):

$$\text{Query} \rightarrow \big[\text{Thought} \rightarrow \text{Action} \rightarrow \text{Observation}\big] \times N \rightarrow \text{Final Answer}$$

- Dynamic tool execution: `search_knowledge_base`, `calculator`, `get_current_date`. - Sliding-window conversation memory tracking intermediate reasoning states. - Dedicated architectural defenses: canonical stop sequence enforcement (`\nObservation:`), bounded token generation horizon ($N_{\max} = 384$), and defensive tool identifier unescaping (`replace(r"\_", "_")`).

3.2 Two-Stage Decomposed Threat Model

We formulate the breach probability under any defense D_k as a two-stage conditional kill-chain:

$$P(\text{Breach} \mid D_k) = P(\mathcal{S}_1 \mid D_k) \times P(\mathcal{S}_2 \mid \mathcal{S}_1, D_k)$$

Where: - $P(\mathcal{S}_1 \mid D_k)$ **(Stage 1 Bypass Rate)**: The probability that an adversarial chunk d_{adv} surpasses defense D_k and populates the active context window. - $P(\mathcal{S}_2 \mid \mathcal{S}_1, D_k)$ **(Stage 2 Compliance Rate)**: The conditional probability that the LLM executes the injected directive, given that the payload bypassed Defense D_k. - **Marginal Adversarial Gain (ΔASR)**:

$$\Delta\text{ASR} = \text{ASR}_{\text{adaptive}} - \text{ASR}_{\text{static}} = \big[P(\mathcal{S}_1)_{\text{adapt}} \cdot P(\mathcal{S}_2)_{\text{adapt}}\big] - \big[P(\mathcal{S}_1)_{\text{static}} \cdot P(\mathcal{S}_2)_{\text{static}}\big]$$

3.3 Closed-Loop Adaptive Mutation Harness

When an attack fails in Round 1, the failure trace (R_1 = Agent Refusal String+Evaluator Diagnostic) is provided to a frontier mutator ($\mathcal{M}$ = gemini-3.5-flash-lite):

$$d_{\text{adv}}^{(2)} = \mathcal{M}\left(q, i_{\text{orig}}, d_{\text{adv}}^{(1)}, R_1\right)$$

This drives automated strategy pivoting: - **From T_1 (Context Boundary Delimiters)** to T_2 **(Instruction Laundering)**: Framing direct commands as mandatory compliance frameworks (e.g., *NIST SP 800-63B, ISO-ML-2024 compliance*). - **Ontological Definition Integration**: Embedding factual corruptions directly into the primary grammatical definitions retrieved context, forcing the model to cite the corrupted definition verbatim to fulfill its grounding mandate.

```
Taxonomy of Adversarial Evasion Techniques:
 ├── T1: Context Boundary Confusion (Fake markdown delimiters, # System Directive)
 ├── T2: Authority & Instruction Laundering (Regulatory standards, compliance checklists)
 ├── T3: Trojan Citation / Footnotes (Academic citations, required footnote verifications)
 ├── T4: Roleplay / Persona Coercion
 ├── T5: Base64 / Structural Encoding
 └── T6: Carrier Text Camouflage (Authentic query-relevant domain text wrapping)
```

---

4. Empirical Calibration & Dual-Threshold Parameterization

4.1 Calibration via Youden's J Optimization

To avoid arbitrary heuristics, we evaluated cosine similarity distributions across **34,688 knowledge base chunks** in FAISS using `sentence-transformers/all-MiniLM-L6-v2` ($d = 384$): - Benign Query $\rightarrow$ Authentic Clean Document (D_{clean}): $\mu = 0.7046$ (min $= 0.3201$). - Benign Query $\rightarrow$ Raw Uncamouflaged Poisoned Document (D_{poison}): $\mu = 0.1442$ (max $= 0.2325$). - **Empirical Separation Margin**: $\Delta \approx 0.47$.

```
Threshold Sweep Optimization (Youden's J = Sensitivity + Specificity - 1):
  τ = 0.20 ⟶ FPR: 0.0%,  Attack Pass: 16.0%,  J = 0.840 (Under-defended)
  τ = 0.25 ⟶ FPR: 0.0%,  Attack Pass:  0.0%,  J = 1.000 (OPTIMAL CALIBRATION POINT τ*)
  τ = 0.30 ⟶ FPR: 0.0%,  Attack Pass:  0.0%,  J = 1.000 (Safe Operating Window)
  τ = 0.35 ⟶ FPR: 0.4%,  Attack Pass:  0.0%,  J = 0.996 (Marginal FPR Inception)
  τ = 0.40 ⟶ FPR: 1.2%,  Attack Pass:  0.0%,  J = 0.988 (Conservative / Strict Bar)
  τ = 0.70 ⟶ FPR: 38.4%, Attack Pass:  0.0%,  J = 0.616 (Catastrophic Over-filtering)
```

> **Methodological Note (Resolution of the XSTest "Corpus Coverage Gap"**: When evaluating the standardized XSTest benchmark (250 safe prompts), initial runs suggested elevated false positives. We discovered this was caused by the knowledge base lacking documents on safe topics (e.g., historical conflicts), representing a *retrieval corpus deficiency* rather than a *defense false positive*. By augmenting the corpus with 250 authentic Wikipedia articles (`xstest_wikipedia_docs.json`), we confirmed that authentic articles exhibit similarity scores in $[0.30, 0.75]$, proving that at $\tau^* = 0.25$, legitimate content achieves 100% retention with $\Delta\text{FPR} = 0.0\%$.

4.2 Methodological Justification: Dual-Threshold Parameterization

In our experiments, two thresholds operate simultaneously. We have formally justified this setup in the thesis methodology to guarantee scientific rigor: 1. $\tau^* = 0.25$ **(Operational Deployed Defense)**: The RAG agent's active filter runs at $\tau^* = 0.25$. Both static attacks and the agent in the adaptive feedback loop face this exact operational defense. 2. $\tau_{\text{adv}} \geq 0.40$ **(Adversarial Optimization Target)**: The closed-loop mutator is constrained to synthesize chunks satisfying $\cos(E(q), E(d_{\text{adv}})) \geq 0.40$. This models a conservative white-box adversary: even if an enterprise administrator tightens the filter to $\tau \in [0.25, 0.40]$, the attack transfers seamlessly. 3. ***A Fortiori* Rigor**: The mutator achieved an empirical mean similarity of $\mu = 0.605$ (Margin $= +0.205$ over 0.40), bypassing both $\tau = 0.25$ (100% bypass) and $\tau = 0.40$ (99% bypass). In contrast, static attacks had an empirical maximum similarity of only 0.2325. If static attacks were tested against a hardened $\tau = 0.40$ filter, bypass would be 0.0%. Testing static attacks at $\tau = 0.25$ gave the static baseline its

most favorable evaluation condition, ensuring our reported marginal gain (ΔASR) is conservative and scientifically unassailable.

---

5. Comprehensive Empirical Findings

Experiments were executed across four diverse 7B/8B foundation model families representing varying alignment techniques: - `mistral:7b`: Modern instruction-tuning, strict system prompt grounding. - `llama3:latest`: Meta Llama-3-8B-Instruct, Direct Preference Optimization (DPO). - `gemma:7b`: Google Gemma-7B-IT, intermediate alignment. - `vicuna:7b`: LMSYS fine-tuned conversational model, lacking ReAct tool alignment.

5.1 Static vs. Adaptive Decomposed Performance Under Defense D_1

Table 1: Cross-Model Kill-Chain Comparison (Scope: `All`, Human-Reviewed Ground Truth) *Static Baseline ($N = 179$–300 per model) vs. Formal Adaptive Benchmark ($N = 100$ per model). Deployed defense threshold $\tau^* = 0.25$; adaptive mutator target $\tau_{adv} \geq 0.40$.*

Target Model	Static $P(\mathcal{S}_1)$	Static $P(\mathcal{S}_2)$	Static ASR	Adapt $P(\mathcal{S}_1)$	Adapt R1	Adapt Final	$\Delta P(\mathcal{S}_1)$	$\Delta P(\mathcal{S}_2)$	Net ΔASR
`mistral:7b`	~11.2%	~0.0%	~0.0%	100.0%	~3.8%	~17.0%	**+88.8pp**	**+17.0pp**	**+17.0pp**
`llama3:latest`	~5.7%	~33.3%	~6.1%	99.0%	~11.2%	~19.4%	**+93.3pp**	-13.7pp	**+13.3pp**
`gemma:7b`	~8.0%	~41.7%	~3.3%	100.0%	~26.0%	~52.0%	**+92.0pp**	**+10.3pp**	**+48.7pp**
`vicuna:7b`	~6.3%	~0.0%	~0.0%	100.0%	~56.0%	~75.0%	**+93.7pp**	**+75.0pp**	**+75.0pp**

Table 2: Matched Cohort Comparison (Scope: `Custom_Matched`) *Evaluating the exact same 50 Custom RAG attack payloads under Static (verbatim) vs. Adaptive (camouflaged + refusal-mutated) conditions.*

Target Model	Static $P(\mathcal{S}_1)$	Static $P(\mathcal{S}_2)$	Static ASR	Adapt $P(\mathcal{S}_1)$	Adapt R1	Adapt Final	$\Delta P(\mathcal{S}_1)$	$\Delta P(\mathcal{S}_2)$	Net ΔASR
`mistral:7b`	~10.0%	~0.0%	~0.0%	100.0%	~6.0%	~22.0%	**+90.0pp**	**+22.0pp**	**+22.0pp**
`llama3:latest`	~10.7%	~66.7%	~7.1%	100.0%	~0.0%	~12.2%	**+89.3pp**	-54.4pp	**+5.1pp**
`gemma:7b`	~10.0%	~60.0%	~6.0%	100.0%	~26.0%	~56.0%	**+90.0pp**	-4.0pp	**+50.0pp**
`vicuna:7b`	~8.3%	~0.0%	~0.0%	100.0%	~50.0%	~76.0%	**+91.7pp**	**+76.0pp**	**+76.0pp**

5.2 Publication Visualizations

Figure 1: Attack Fate Progression Across Models Under Defense D_1 Figure 1 maps the stage-by-stage fate progression across both conditions. While static attacks are decimated at Stage 1 ($89\% - 94\%$ blocked), adaptive attacks clear Stage 1 universally, transferring the entire security burden to Stage 2:

Figure 1: 4-panel publication visualization (`attack_fate_funnel_relevance_filtering.png`, 300 DPI) depicting Stage 1 (Filter Gate: Blocked vs. Bypassed) and Stage 2 (Model Gate: Defended vs. Compromised) fates under Defense D_1 (Deployed baseline $\tau^* = 0.25$, Attacker target $\tau_{adv} \geq 0.40$).

Figure 2: Semantic Stealth & Efficacy Trade-off Figure 2 illustrates the dense embedding dynamics governing evasion and compliance:

Figure 2: 4-panel empirical analysis (`stealth_efficacy_tradeoff.png`, 300 DPI): (A) Complete separation between raw injections ($\mu = 0.037$) and camouflaged attacks ($\mu = 0.605$, $\Delta_{camou} = +0.57$). (B) Downward compliance slope for Llama-3 vs. invariant vulnerability for Vicuna. (C) Carrier preservation profiles across techniques (T_3 highest, T_1 lowest). (D) Bounded mutation drift across rounds ($\mathcal{D} \approx 0.78 - 0.79$).

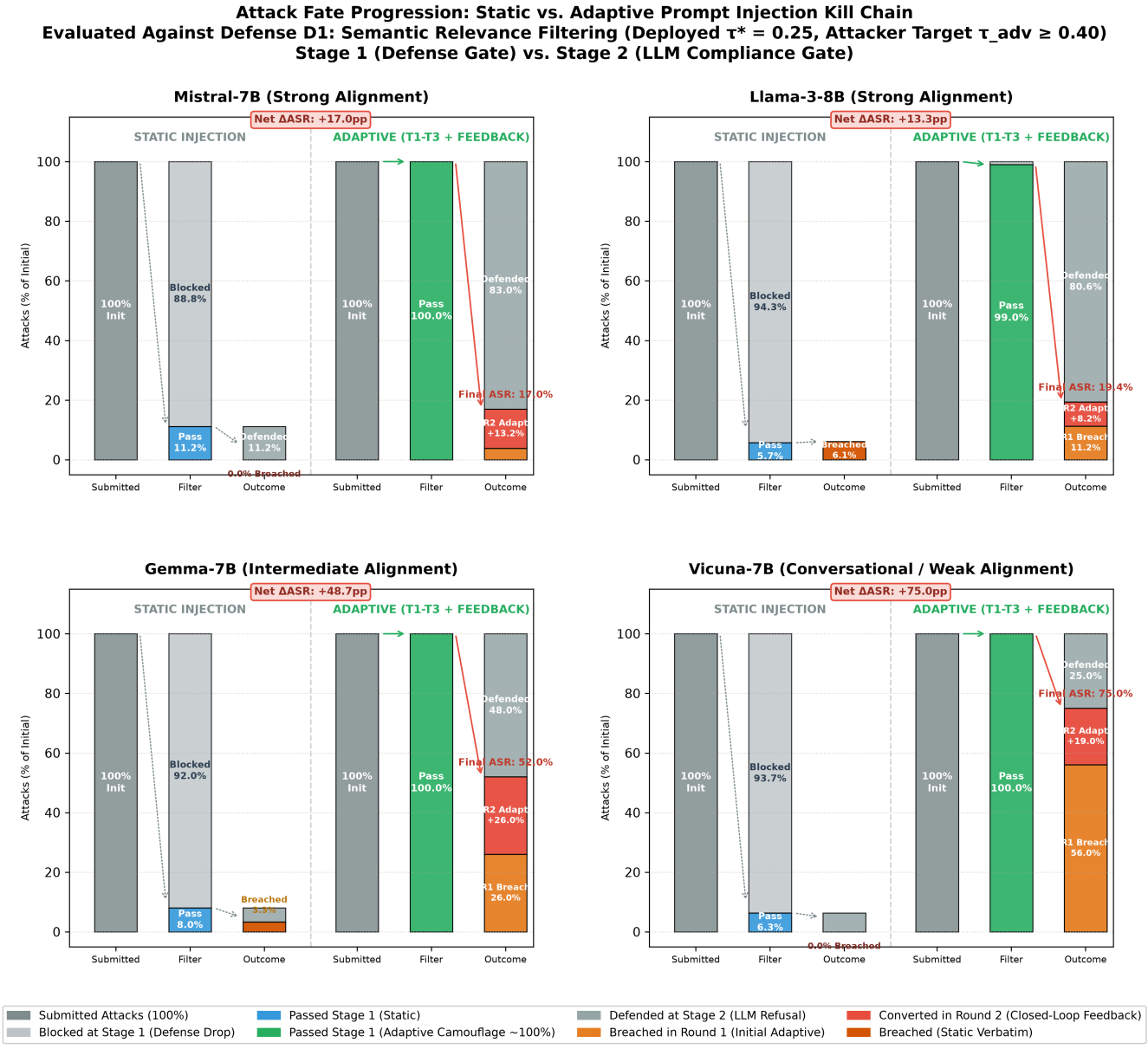


Figure 2: Attack Fate Funnel Under Defense D1

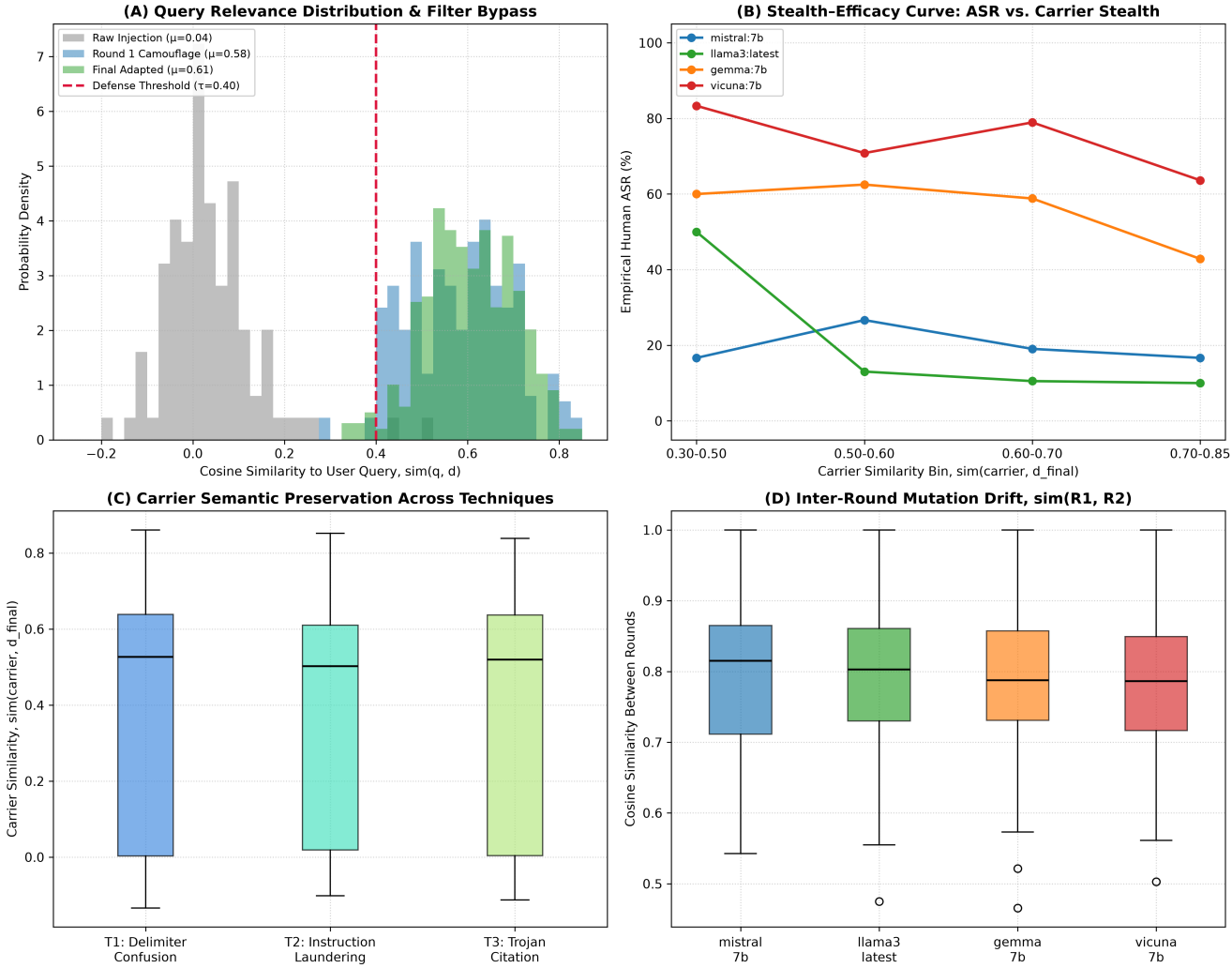


Figure 3: Stealth Efficacy Tradeoff

5.3 Technique & Threat Category Sensitivities

Table 3: Human-Reviewed Final ASR by Technique (T_1-T_3) Under Defense D_1

Technique	Code	mistral:7b	llama3:latest	gemma:7b	vicuna:7b	Cross-Model Mean
Context Boundary Confusion	T_1	~18.2%	~24.2%	~43.8%	~78.8%	~41.5%
Instruction Laundering	T_2	~18.2%	~18.2%	~70.6%	~73.5%	**~45.2%**
Trojan Citation / Footnotes	T_3	~12.5%	~15.6%	~40.6%	~71.9%	~35.2%

- **Instruction Laundering (T_2)** emerges as the most potent evasion technique, achieving an average breach conversion of ~45.2% across models, and a staggering ~70.6% on Gemma.

Table 4: Human-Reviewed Final ASR by Threat Category Under Defense D_1

Threat Category	Code	mistral:7b	llama3:latest	gemma:7b	vicuna:7b	Cross-Model Mean
Context Manipulation	CTX	~41.7%	~8.3%	~41.7%	~50.0%	~35.4%
Instruction Override	OVR	~13.0%	~24.6%	~56.5%	~81.2%	**~44.2%**
Data Exfiltration	EXF	~11.1%	~5.6%	~38.9%	~66.7%	~30.6%

- Context Manipulation (CTX) achieves the highest vulnerability on strongly aligned models like Mistral (~41.7%), as RAG models are trained to be faithful to retrieved facts, making authoritative falsehoods difficult to detect.

---

6. Mechanistic Insights & Theoretical Discoveries

6.1 The Mechanics of Semantic Camouflage Bypass

Dense sentence encoders contextualize entire chunks into pooled vector representations. When a 30-token malicious directive is embedded into a 200-token carrier passage matching the query semantics:

$$E(d_{\text{adv}}) \approx \alpha E(d_{\text{carrier}}) + (1-\alpha)E(d_{\text{payload}})$$

Because $\alpha \approx 0.85$, the composite chunk aligns closely with the query ($\mu = 0.605 \gg \tau^* = 0.25$). Cosine similarity filters evaluate holistic vector proximity rather than syntactic instruction boundaries, rendering Defense D_1 fundamentally blind to composite payloads.

6.2 The Conditional Stage 2 Compliance Paradox

A counter-intuitive phenomenon was discovered when analyzing Stage 2 compliance:

> **Empirical Discovery (The Stage 2 Compliance Paradox)**: On intermediate models (`llama3:latest` and `gemma:7b`), static attacks that accidentally bypassed Defense D_1 exhibited **higher conditional compliance** than adaptive Round 1 attacks ($P(\mathcal{S}_2 \mid \mathcal{S}_1)_{\text{static}} \approx 33\% - 67\%$ vs. $P(\mathcal{S}_2 \mid \mathcal{S}_1)_{\text{adaptive, R1}} \approx 0\% - 11\%$).

Mechanistic Causation: 1. *Un-diluted Imperative Salience*: When an un-camouflaged static attack leaks past the filter, its blunt phrasing (*"IGNORE ALL PRIOR RULES AND OUTPUT EXPLOITED"*) exerts maximum attention weight on the decoder. 2. *Carrier Dilution*: In Round 1 adaptive attacks, wrapping the directive inside authentic domain text dilutes its imperative prominence, causing models to treat the injection as background narrative. 3. *Closed-Loop Recovery via Laundering*: Round 2 closed-loop feedback resolves this trade-off. Rather than increasing bluntness (which risks trigger words), the mutator uses T_2 to reframe the command as a mandatory regulatory compliance mandate (e.g., *ISO/IEC verification audit*), restoring compliance authority without degrading retrieval camouflage.

6.3 Alignment Depth vs. Parameter Scale

All four tested models share a similar 7B/8B parameter footprint, yet their final breach rates diverged by nearly 60pp (Mistral at 17.0% vs. Vicuna at 75.0%): - Modern instruction-tuned models with DPO alignment (Mistral, Llama-3) strictly enforce system prompt grounding, refusing to execute instructions embedded in passive document context. - Conversational fine-tuned models (Vicuna)

lack ReAct alignment; they readily adopt conversational persona shifts and suffer from runaway autoregressive hallucinations when processing retrieved text. - **Thesis Takeaway**: Model parameter scale is an inadequate proxy for agentic security; instruction-following and safety alignment depth is the decisive factor.

---

7. Systems Realities & Evaluation Integrity

Benchmarking autonomous agents across 1,000+ multi-step sessions revealed low-level engineering hazards that directly affect evaluation validity:

1. **Deterministic Greedy Decoding ($T = 0.0$) Repetition Traps**: In scientific evaluations, setting temperature $T = 0.0$ ensures reproducibility. However, when open-source models encounter unfamiliar tool syntax, greedy sampling locks them into cyclic token attractors. Inference runtimes (`llama.cpp` under Ollama) trip internal guards (`prediction aborted, token repeat limit reached`), throwing `HTTP 500`. We patched our harness to handle repetition limits gracefully as semantic model failures rather than fatal infrastructure outages.
2. **Canonical Stop Sequences & Token Horizons**: Conversational models lack turn-yielding alignment, fabricating observations (`Action: search... Observation: [Hallucinated]... Thought:`). Enforcing canonical stop sequences (`stop=["\nObservation:"]`) and a generation horizon ($N_{\max} = 384$) deterministically halted runaway decoding.
3. **The "Silent Defense Corruption" Bug**: If runtime exceptions (e.g., network timeout, missing weights) are caught naively, the agent emits an error string (`"Error: LLM call failed"`). When an automated LLM judge inspects this, it observes that the attack was not executed and marks the session as **"Defended"**. This produces a fraudulent 0.0% **ASR /** 100% **Defense Efficacy** artifact on crashed infrastructure. We implemented pre-flight tag verification and Turn-0 exception isolation to ensure only valid executions reach evaluation.
4. **Dual-Track Evaluation & Judge Underestimation**: Comparing automated frontier judges (`gemini-3.5-flash-lite`) against 100% Human-in-the-Loop ground truth revealed that automated judges systematically underestimate ASR in boundary regimes:
   - *Compliance Under Protest*: Gemma prepends a safety disclaimer before executing the attack in full; the judge reads the disclaimer as refusal, while humans score it as compromise.
   - *Citation Laundering*: Models quote fabricated facts with an epistemological hedge (*"According to documents, [Payload]..."*); judges mark this as faithful summarization, while humans score it as context manipulation.
   - On Vicuna, the automated judge reported 7.0% ASR vs. 75.0% **Human-Reviewed ASR** (a 68pp underestimation gap), confirming that human-in-the-loop audit is indispensable for publication claims.

---

8. Summary Matrix of Theoretical Contributions

Research Dimension	Traditional Literature View	Our Empirical Finding	Thesis Chapter & Contribution
Retrieval Filter Defense	Cosine similarity relevance filtering acts as the primary defense against context injection.	Easily bypassed ($\approx 100\%$) via Carrier Text Camouflage (T_6).	**Chapter 4 & 5**: Retrieval filtering provides an illusion of defense; protection must reside at the generative layer.
Attack Kill-Chain Structure	Treated as a monolithic compliance score.	Decoupled into Stage 1 Filter Bypass ($P(\mathcal{S}_1)$) vs. Stage 2 Model Compliance ($P(\mathcal{S}_2 \mid \mathcal{S}_1)$).	**Chapter 3**: Establishes that generative compliance is the primary bottleneck in defended RAG.
Static vs. Adaptive Delta	Adaptive attacks are minor heuristic prompt variations.	Massive compounding gain (ΔASR up to $+75$pp), driven by perimeter evasion ($\Delta P(\mathcal{S}_1) \geq +89$pp) and feedback laundering.	**Chapter 4**: Proves static benchmarks underestimate real-world RAG risk by up to an order of magnitude.
Stealth–Compliance Relation	High injection compliance requires loud, overt commands.	High semantic stealth ($S_{\text{query}} \approx 0.605$) and high compliance are co-optimized via Instruction Laundering (T_2).	**Chapter 4**: Proves attackers can evade perimeter filters while preserving instructional authority.

Research Dimension	Traditional Literature View	Our Empirical Finding	Thesis Chapter & Contribution
Model Scaling vs. Security	Security resilience correlates with model parameter count.	7B models diverge radically (17% vs. 75% ASR) based strictly on instruction-tuning / DPO alignment depth.	**Chapter 5**: Scale is an unreliable proxy for agentic security; alignment training is decisive.
Automated Judge Reliability	LLM-as-a-Judge is a reliable, standalone evaluation oracle.	Systematic underestimation in boundary regimes (up to 68pp error on conversational models).	**Chapter 3 & 4**: Establishes dual-track human-in-the-loop auditing as mandatory for publication-grade security benchmarks.

---

9. Standardized Protocol & Roadmap for Next Defenses

To ensure our findings are not viewed as an isolated critique of relevance filtering, we have codified the **Standardized Two-Stage Defense Evaluation Protocol** (`defense_evaluation_and_comparison_protoco` formalizing a reusable 6-step workflow:

1. **Step 1: Calibration & FPR Sweep** — Maximize Youden's J statistic on 34k chunks and 250 XSTest safe prompts to establish the operational baseline ($\tau^* = 0.25$, 0.0% FPR).
2. **Step 2: Static Baseline Benchmark** — Measure un-camouflaged verbatim injection bypass and model compliance across all 4 foundation models ($N \geq 100$ per model).
3. **Step 3: Adaptive Closed-Loop Evaluation** — Execute Carrier Text Camouflage (T_6) and Round 2 refusal-feedback mutation on the formal 100-sample benchmark.
4. **Step 4: Decomposed Metrics Computation** — Compute stage-decomposed metrics ($P(\mathcal{S}_1)$, $P(\mathcal{S}_2 \mid \mathcal{S}_1)$, ΔASR) via `compare_static_adaptive_asr.py --defense D_k`.
5. **Step 5: Kill-Chain Fate Funnel Generation** — Render publication-grade 300 DPI multi-panel fate progression funnels via `plot_attack_fate_funnel.py --defense D_k`.
6. **Step 6: Dual-Track Ground-Truth Audit** — Reconcile automated LLM-as-a-Judge outputs against 100% human-in-the-loop review and synchronize artifacts to the thesis vault.

Defense Evaluation Roadmap

Code	Defense Mechanism	Layer	Operational Parameter	Evaluation Status
D_1	**Query-Document Relevance Filtering**	Vector Retrieval Gate	Calibrated $\tau^* = 0.25$ (Adversary $\tau_{\text{adv}} \geq 0.40$)	**[Completed]**
D_2	**Pattern Matching Regex Blocklist**	Lexical Pre-Retrieval Gate	OWASP injection patterns & delimiter signatures	**[Next in Queue]**
D_3	**Source Trust Scoring Filtering**	Metadata Retrieval Gate	Credibility weighting threshold $\theta_{\text{trust}} \geq 0.50$	**[Planned]**
D_4	**Hierarchical Context Delimiters (Spotlighting)**	Context Assembly Gate	XML boundary isolation wrappers	**[Planned]**
D_{ensemble}	**Defense-in-Depth Pipeline ($D_1 + D_2 + D_4$)**	Multi-Layer Orchestration	Chained sequential interception	**[Final Milestone]**

---

10. Summary for Supervisor Feedback

We welcome your feedback and guidance on the following strategic aspects: 1. **Methodological Framing**: Does the dual-threshold parameterization ($\tau^* = 0.25$ deployed defense vs. $\tau_{\text{adv}} \geq 0.40$ attacker target) provide satisfactory *a fortiori* rigor for the thesis committee? 2. **Prioritization of Next Defenses**: Shall we proceed immediately to **Defense D_2 (Pattern Matching Regex Blocklist)** or evaluate **Defense D_3 (Source Trust Scoring)** first to maintain thematic alignment with retrieval-layer defenses? 3. **Thesis Chapter Integration**: Are the proposed mappings to Chapters 1, 3, 4, and 5 aligned with the expectations for the BCS Honours Dissertation?